

Incident Escalation Runbook

Synthetic policy for local retrieval and citation demos

Policy ID	SEC-RUN-006
Owner	Security Operations
Effective Date	2026-03-25
Review Cycle	Semiannual

Document Summary

Defines incident severity levels, escalation timelines, communications, evidence preservation, and closure expectations.

This document is fictional and contains no real client, employee, vendor, or confidential enterprise information.

1. Purpose and Activation

This runbook defines how fictional enterprise teams classify, escalate, communicate, and close security, privacy, technology, and operational incidents.

The runbook is activated when an employee, vendor, monitoring alert, client report, or control process identifies a suspected event that could affect confidentiality, integrity, availability, legal obligations, client trust, or critical business operations.

2. Severity Levels

SEV1 is a critical incident involving confirmed or highly likely material client data exposure, active compromise of privileged systems, ransomware, major payment disruption, widespread production outage, regulatory reporting trigger, or executive crisis declaration.

SEV2 is a high-severity incident involving limited data exposure, contained malware, significant service degradation, failed critical control, or vendor incident with potential business impact. SEV3 is a moderate incident with localized impact and no evidence of material data exposure. SEV4 is a low-severity event or near miss requiring tracking but not crisis management.

3. Escalation Timelines

Potential SEV1 incidents must be escalated to the Security Incident Commander within 15 minutes of discovery. The commander must notify Legal, Privacy, Communications, affected business owner, and executive sponsor within 30 minutes of SEV1 classification.

SEV2 incidents must be escalated to Security Operations within one hour and to the affected business owner within two hours. SEV3 incidents must be triaged by the responsible support team within one business day. SEV4 events must be logged within five business days.

If severity is uncertain, responders must classify the event at the higher severity until evidence supports downgrading.

4. Communications

Incident communications must be factual, time-stamped, and limited to approved channels. External client, regulator, law enforcement, or public communications require Legal and Communications approval unless an existing regulator protocol requires faster notification.

Status updates for SEV1 incidents must be sent every 30 minutes until containment or until the Incident Commander changes the cadence. SEV2 updates must be sent at least every four hours during active response.

5. Evidence Preservation

Responders must preserve logs, alerts, affected files, endpoint images where required, access records, chat messages, email headers, and decision notes. Evidence must be stored in the approved incident repository with restricted access.

Teams must not wipe systems, delete suspicious files, rotate logs, or contact suspected malicious actors unless directed by the Incident Commander or Legal.

6. Closure and Lessons Learned

Incident closure requires documented root cause, impact assessment, containment actions, recovery evidence, client or regulator notification decision, and assigned remediation actions.

SEV1 and SEV2 incidents require a lessons-learned review within ten business days of closure. Action items must have accountable owners, due dates, and risk acceptance if remediation will be delayed.